

RAPPORT DES TESTS STATIQUES — BIPROJECT QA

Projet : BiProject
Auteurs : Youssef Chaari & Mohamed Aziz Zouari
Date : 15 Mars 2026
Version : 1.2 (Harmonisée)

1. Introduction

Les tests statiques visent à identifier des défauts et vulnérabilités sans exécution du code. Cette approche a permis de détecter des failles de conception majeures avant la phase dynamique.

2. Registre des Anomalies Détectées

ID	Localisation	Type d'Anomalie	Gravité
AN-01	OrderController.cs	IDOR (Broken Access Control)	Critique
AN-02	OrderCreateDto.cs	Trust Boundary Violation	Majeure
AN-03	AuthService.cs	Absence de Logging d'audit	Mineure

3. Analyse Détaillée et Recommandations

3.1 AN-01 : IDOR sur la récupération de commande

- Impact :** Un utilisateur peut visualiser les factures ou commandes n'importe quel autre utilisateur en manipulant l'ID dans l'URL.
- Recommandation :** Valider l'appartenance de la ressource en base de données en utilisant l'ID utilisateur extrait du Token JWT sécurisé.

3.2 AN-02 : Violation de la frontière de confiance

- Impact :** Le `UserId` est accepté tel quel depuis le client, permettant à un utilisateur de créer des commandes au nom de tiers.
- Recommandation :** Ignorer le `UserId` fourni dans le corps de la requête. Utiliser exclusivement `User.FindFirstValue(ClaimTypes.NameIdentifier)` côté serveur.

3.3 AN-03 : Manque d'audit sur l'authentification

- Impact :** Difficulté à détecter les attaques par force brute ou les comportements suspects de connexion.
- Recommandation :** Injecter un service de logging (`ILogger`) et tracer chaque échec d'authentification avec le nom d'utilisateur et l'adresse IP.

4. Revue de Qualité des Scripts de Test

L'analyse statique des scripts de test (Selenium et xUnit) révèle une excellente application des standards :

- Usage systématique du pattern **AAA** (Arrange, Act, Assert).
- Implémentation rigoureuse du **Page Object Model (POM)**.
- Isolation des environnements de test via des fixtures.

Fin du rapport statique.